

سند SANAAD

Comprehensive Approach Document

Re-Engineering from Broadcom Layer7 / Kony to Flutter + Node.js

Client: Hamad Medical Corporation (HMC)

Project Codename: SANAAD-MOBILE-APP

Version 0.3 | March 2026

Status: Draft for Review

Document Classification: Confidential — HMC Internal Use. Contains proprietary solution architecture and must not be distributed outside the project team without written approval.

Table of Contents

Table of Contents	2
1. Executive Summary	4
1.1 What We Are Changing and Why	4
1.2 Why Replace the Current Platform?	4
2. Application Scope — Three-Phase Delivery	5
2.1 Phase 1 — Finalised Scope (8 Weeks)	5
2.2 Phase 2 — Extended Services (6 Weeks)	6
2.3 Phase 3 — Advanced Features (6 Weeks)	6
3. Current State Overview	7
3.1 The Broadcom Layer7 API Gateway	7
3.2 The Kony Mobile Platform	7
4. Migration Strategy	8
4.1 Approach: Build in Parallel, Cut Over Gradually	8
4.2 Transition from the Current System	8
4.3 Database Access Strategy	8
5. Technology Choices	9
5.1 Technology Overview	9
5.2 Mobile App Structure	10
5.3 Backend Service Structure	10
6. Solution Architecture	11
6.1 How the System Works End-to-End	11
6.2 Authentication Flow	11
7. Security Architecture	12
7.1 Security Approach	12
7.2 Gateway Security Configuration	12
8. API & Integration Design	13
8.1 API Overview	13
8.2 Service Responsibilities	13
8.3 API Standards	13
9. User Experience & Bilingual Design	14
9.1 Design Principles	14
9.2 Arabic & English Support	14
10. Implementation Roadmap	15
10.1 Delivery Timeline	15
10.2 Team Structure	15
10.3 Phase 0 — Foundation Checklist	16

10.4 Security Testing Checklist.....	16
11. Infrastructure & Deployment.....	17
11.1 Server Layout.....	17
11.2 High Availability.....	17
11.3 Monitoring.....	17
12. Risk Register.....	18
13. Assumptions & Open Items.....	19
13.1 Assumptions.....	19
13.2 Open Items.....	19

1. Executive Summary

Hamad Medical Corporation (HMC) operates SANAAD (سند), an employee self-service mobile application that currently runs on the Kony (Temenos Quantum) platform with a Broadcom Layer7 API Gateway handling security and routing. The app is used by thousands of HMC employees for everyday tasks such as viewing payslips, managing leave requests, handling approvals, booking staff clinic appointments, accessing housing information, and more.

This document outlines our approach to rebuilding SANAAD using modern, open-source technologies — specifically Flutter for the mobile app and Node.js for the backend services. The new system will replace both the Kony mobile platform and the Broadcom Layer7 gateway with a more flexible, cost-effective, and maintainable solution.

The project is organised into three delivery phases, each building on the previous one to progressively deliver all application features to HMC employees.

1.1 What We Are Changing and Why

Area	Current State	Target State
Mobile App	Kony (Temenos Quantum) — proprietary platform	Flutter — open, cross-platform, modern
Backend Gateway	Broadcom Layer7 — commercial appliance with licensing costs	Node.js + NGINX — open source, no licensing fees
Security	Layer7 OAuth toolkit (commercial)	Industry-standard JWT tokens, SSL pinning, encryption
Arabic Support	Limited Arabic / RTL support	Full Arabic and English parity with native RTL
Database Access	Kony middleware	Direct Oracle connection pooling — faster and more reliable
Deployment	VM/Appliance based	Docker containers on existing HMC servers
Monitoring	Precision API Monitoring (paid add-on)	Open-source monitoring with HMC SIEM integration

1.2 Why Replace the Current Platform?

The decision to move away from both Kony and Broadcom Layer7 is driven by several practical factors:

- Cost savings: Eliminating commercial licensing fees for both the mobile platform and the API gateway
- Talent availability: Flutter and Node.js have large developer communities, making it easier to find and retain skilled staff
- Better Arabic support: Flutter handles right-to-left layouts natively, providing a much better experience for Arabic-speaking users
- Modern development practices: Docker containers and CI/CD pipelines enable faster, more reliable releases
- Performance: Flutter compiles to native code, removing the overhead of the current JavaScript bridge
- Flexibility: Open-source technologies give HMC full control without vendor dependencies

2. Application Scope — Three-Phase Delivery

The project delivers SANAAD features across three phases. Phase 1 is fully defined and currently in active delivery. Phases 2 and 3 are planned for forward compatibility and will be refined as the project progresses.

2.1 Phase 1 — Finalised Scope (8 Weeks)

Phase 1 covers the core employee self-service features that are most frequently used:

Module	English	Arabic	Description
Authentication	Login / SSO / MPIN / Biometrics	تسجيل الدخول	Secure login with multiple authentication options
Payslip	Payslip	قسمة الراتب	View and download monthly payslips
Leaves	Leaves & Tickets	الإجازات	Submit, amend, and cancel leave requests
Personal Details	My Personal Details	بياناتي الشخصية	View and update personal information
Employment Details	My Employment Details	بيانات التوظيف	View employment and contract details
Letters	Request Letters	طلب خطابات	Request official letters and certificates
Approvals	Approvals	الموافقات	Review and approve/reject pending requests
Annual Ticket	Request for Annual Ticket	تذكرة سنوية	Submit annual travel ticket requests
Staff Clinic	Staff Clinic — Appointments	العيادة الطبية	Book, cancel, and reschedule clinic appointments
Housing	Housing: Contact, Location, Portal	الإسكان	Access housing information and documents
Sogha	View Sogha Card	صوغة	View employee privilege card
Performance	Performance View Screen	الأداء	View performance evaluations
Settings	Notifications, Biometric toggle	الإعدادات	Manage notification and security preferences

2.2 Phase 2 — Extended Services (6 Weeks)

Phase 2 adds additional employee services and housing-related features:

Module	Description
Request for Loan	HR loan application workflow
Request for Accommodation	Housing allocation and request process
Maintenance Requests	Facilities management requests
Services: Telephone / Electricity	Utility service request workflow
Request for Furniture Loan	Furniture loan catalogue with approval process
Housing Department Instructions	Instructional content for housing residents
Sogha: Categories, Offers, T&C, FAQs	Extended employee privilege portal
Profile — Resident Permit Renewal	QID and residence permit update process

2.3 Phase 3 — Advanced Features (6 Weeks)

Phase 3 delivers advanced HR and employee development features:

Module	Description
Accommodation Relocation / Vacating / Evacuation Certificate	Housing lifecycle management
Performance Monitoring, Goals, Appraisals, Appeal	Full performance management suite
Request for Allowances / Promotions & Increments	HR workflow for compensation changes
Profile — Transfer Sponsorship	Immigration and HR sponsorship workflow
Courses & Training	Learning management system integration
Chat Bot	AI-assisted employee self-service
Attendance	Time and attendance tracking integration

3. Current State Overview

The existing SANAAD system consists of two main components that are being replaced:

3.1 The Broadcom Layer7 API Gateway

The current backend uses Broadcom Layer7, a commercial API gateway appliance that handles security, routing, and traffic management. While functional, it presents several challenges:

- Commercial licensing costs that increase with capacity
- Requires specialist knowledge to configure and maintain
- Runs as a virtual machine appliance, limiting deployment flexibility
- Additional paid monitoring add-on (Precision API Monitoring)

All security and routing capabilities provided by Layer7 will be fully replicated in the new Node.js-based backend, with no reduction in security posture.

3.2 The Kony Mobile Platform

The current mobile app is built on Kony Visualizer (Temenos Quantum), a proprietary low-code platform. Key reasons for moving to Flutter:

- Vendor lock-in: Kony uses a proprietary development approach with no open-source alternative
- Limited Arabic support: RTL layout quality is constrained by the platform's abstraction layer
- Performance limitations: Flutter's compiled approach offers significantly better responsiveness
- Talent scarcity: Kony specialists are rare; Flutter developers are widely available

4. Migration Strategy

4.1 Approach: Build in Parallel, Cut Over Gradually

The new Flutter app and Node.js backend are built alongside the existing live system. We verify that each feature works correctly before switching users over. This approach eliminates the risk of a sudden “big bang” switchover and allows real HMC employees to test the new system incrementally.

Phase	Title	Duration	Success Criteria
Phase 0	Foundation & Setup	Week 1	Server infrastructure ready; development pipeline operational; all existing API connections verified
Phase 1	Core Modules	Weeks 2–9 (8 weeks)	All Phase 1 features at testing-ready quality; security testing initiated
Phase 2	Extended Services + Testing	Weeks 10–15 (6 weeks)	Phase 2 features complete; user acceptance testing signed off; existing system maintained as fallback
Phase 3	Advanced Features	Weeks 16–21 (6 weeks)	Phase 3 features complete per agreed timeline
Cutover	Production Go-Live	Week 22+	No critical security findings; production database schema live; support plan in place

4.2 Transition from the Current System

- Phase 0: New system is set up alongside the existing system; current platform continues serving all users
- Phase 1 Go-Live: New app begins handling production traffic; existing system kept as a backup for 4 weeks
- Phase 2 Go-Live: Old system moved to standby; Kony app deactivated
- Decommission: Layer7 license retired after confirming stability; server resources reclaimed

4.3 Database Access Strategy

The system connects to Oracle for all employee data. During development, a standard development account is used in an isolated network. For testing and production, HMC’s database team will set up a dedicated, restricted-access account following HMC’s established security process (MD-120).

Important: No development-level database credentials will ever be used in the production environment. This is enforced both by system configuration and network-level controls.

5. Technology Choices

5.1 Technology Overview

The following table summarises the key technology decisions and what they replace:

Component	New Technology	Replaces	Why
Mobile App	Flutter (Dart) 3.41.5	Kony Visualizer	Single codebase for iOS and Android; native Arabic RTL; fast performance
App State Management	Riverpod 3.0.2	Kony data bindings	Modern, testable state management for Flutter
App Navigation	GoRouter 17.2.2	Kony navigation	Supports deep links and modern navigation patterns
API Gateway	NGINX + Kong 1.29.8 3.9.1	Broadcom Layer7	Open source; handles security, routing, and traffic management
Authentication	Node.js auth service	Layer7 OAuth Toolkit	Purpose-built for mobile login with MPIN and biometrics
Backend Services	Node.js + Express 22.20.0 LTS 5.2.0	Kony Foundry + Layer7	Open source; efficient handling of Oracle database calls
Oracle Driver	node-oracledb 6.7.2	Kony Oracle connector	Official Oracle driver with connection pooling
Directory Service	Idapjs 3.0.7	Layer7 LDAP provider	Secure employee directory authentication
Document Access	MS Graph API 3.0.7	Layer7 routing	Direct SharePoint access for documents and forms
Monitoring	Prometheus + ELK 3.11.3 9.0.3	Precision API Monitoring	No licensing cost; integrates with HMC's security systems
Secret Management	HashiCorp Vault 2.0.0	Layer7 certificate store	Encrypted credential storage with audit trail
CI/CD Pipeline	GitLab CI 18.4	Kony Cloud Build	Automated build, test, and deployment pipeline
Container Runtime	Docker v29	VM/Appliance	Consistent environments across development, testing, and production

5.2 Mobile App Structure

The Flutter mobile app is organised using Clean Architecture, a well-established design pattern that separates the application into distinct layers. This makes the code easier to test, maintain, and extend over time.

Key feature areas in the app include: Authentication, Payslip, Leaves, Approvals, Profile, Staff Clinic, My Requests, Housing, Performance, and Sogha — each implemented as an independent module.

5.3 Backend Service Structure

The backend is divided into focused services, each responsible for a specific area:

- API Gateway (NGINX/Kong): Handles all incoming traffic, security checks, and routing
- Auth Service: Manages user login, OTP verification, MPIN, and session tokens
- Oracle Service: Handles all interactions with the Oracle EBS database
- SharePoint Service: Retrieves documents and forms from SharePoint
- Notification Service: Sends push notifications to Android and iOS devices

6. Solution Architecture

6.1 How the System Works End-to-End

The new architecture preserves HMC's existing two-tier security zone design (web tier and application tier) while replacing the commercial Layer7 appliance with modern, containerised services:

1. The Flutter mobile app connects securely over HTTPS with certificate pinning

2. Traffic enters the Web Tier (mwb servers) where NGINX/Kong handles security, authentication verification, rate limiting, and routing
3. Requests are forwarded to the Application Tier (mapp servers) where the Node.js services process business logic
4. Backend services connect to Oracle EBS, Active Directory, SharePoint, and Oracle Health as needed

All communication between tiers is secured and monitored, maintaining the same security standards as the current Layer7 architecture.

6.2 Authentication Flow

The login process provides multiple layers of security while remaining user-friendly:

Step	What Happens
1	Employee opens the SANAAD app and enters their HMC username and password
2	The system verifies credentials against Active Directory (LDAP)
3	A one-time password (OTP) is sent to the employee's registered mobile number
4	Employee enters the OTP to verify their identity
5	On first login, the employee sets up a personal MPIN for quick future access
6	A secure session token is issued, valid for 8 hours with a 30-day refresh option
7	All subsequent requests use this token — no need to log in again during the session

7. Security Architecture

7.1 Security Approach

Security is built into every layer of the new system. Every security capability currently provided by the Broadcom Layer7 gateway is replicated or improved in the new architecture:

Security Concern	How It Is Addressed
Encrypted Communications	All traffic uses HTTPS with TLS 1.3; no unencrypted communication is allowed
Certificate Pinning	The mobile app verifies the server's identity to prevent man-in-the-middle attacks
Authentication	Multi-factor: LDAP credentials + OTP + MPIN/Biometric
Session Security	Secure JWT tokens with asymmetric encryption (RS256)
Rate Limiting	Automatic protection against excessive requests and potential abuse
Input Validation	All data submitted to the system is validated against defined rules
CORS Protection	Only authorised origins can make requests to the backend
Device Security	Detection of rooted/jailbroken devices; code obfuscation
Credential Storage	All sensitive credentials stored in encrypted vault (HashiCorp Vault)
Audit Logging	All system activity is logged and exported to HMC's security monitoring system (SIEM)
Request Tracing	Every request receives a unique tracking ID for end-to-end monitoring

7.2 Gateway Security Configuration

Control	Configuration
Encryption	TLS 1.2 minimum, TLS 1.3 preferred; HTTP automatically redirected to HTTPS
Token Verification	All requests must carry a valid session token; missing tokens are rejected
Rate Limiting	100 requests per minute per user; 10 per minute for login attempts
Request Size Limit	Maximum 5 MB per request to prevent abuse
Access Control	Token-based role verification for all protected endpoints
Security Headers	Standard protective headers applied to all responses
Error Handling	Structured error responses; no internal system details exposed to users

8. API & Integration Design

8.1 API Overview

The system manages approximately 75 API endpoints that connect the mobile app to HMC's backend systems:

Category	Count	Type	Backend System
Authentication	5	Login and security	Active Directory + Oracle
Read Operations	46	Data retrieval	Oracle EBS
Write Operations	28	Data submission	Oracle EBS
Staff Clinic	6	Appointment management	Oracle Health / Cerner
Personal Details	1 (complex)	Multi-source data retrieval	Oracle EBS (10 data sources)

8.2 Service Responsibilities

Each backend service owns a specific set of APIs:

Service	Responsibilities	Replaces
Auth Service	Login, OTP, MPIN, session management (5 APIs)	Layer7 OAuth Toolkit + LDAP provider
Oracle Service	All Oracle EBS data operations: personal info, leaves, payslip, approvals, and more (64 APIs)	Kony Foundry + Layer7 Oracle routing
SharePoint Service	Housing forms and downloadable documents	Layer7 SharePoint routing
Oracle Health Service	Staff clinic: appointment slots, booking, cancellation, rescheduling (6 APIs)	Layer7 Cerner routing

8.3 API Standards

- All APIs are versioned (e.g., /api/v1/) to allow for future updates without breaking existing functionality
- Responses follow a consistent format with clear success/error indicators and bilingual messages (Arabic and English)
- List endpoints use cursor-based pagination for efficient data loading
- All dates use the international ISO 8601 standard; display formatting is handled by the mobile app

9. User Experience & Bilingual Design

9.1 Design Principles

The app design follows HMC's established branding with the following colour palette and layout guidelines:

Element	Value	Usage
Primary Blue	#0079C1	Headers, buttons, active indicators
Light Blue	#BFDCEB	Card backgrounds, table stripes
Very Light Blue	#EAF7FD	Input field backgrounds
Body Text	#58595B	All body text and field labels
Green Accent	#8AC75A	Approved/confirmed status indicators
White	#FFFFFF	Footer, card surfaces
Submit Blue	#0072B6	Submit button backgrounds

9.2 Arabic & English Support

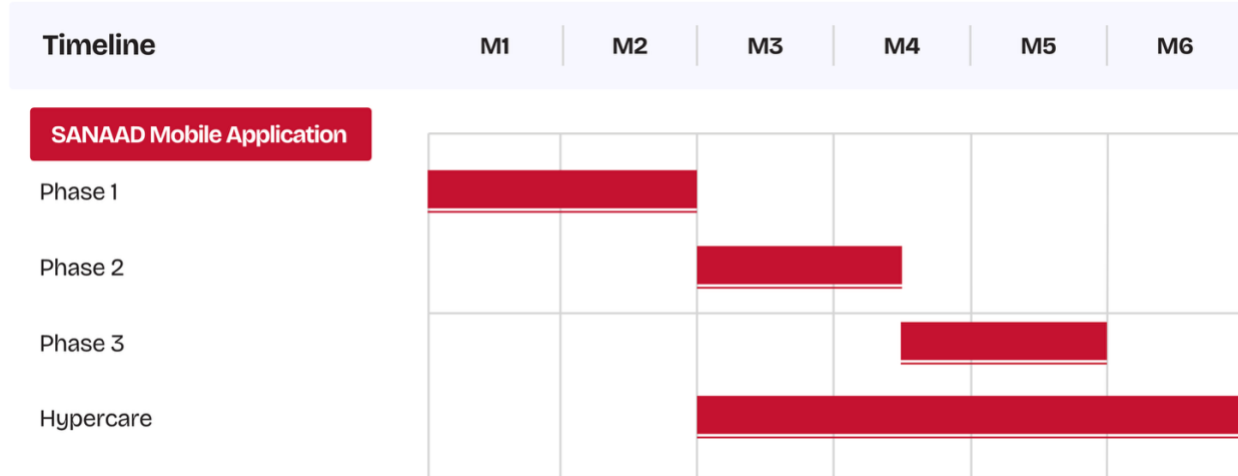
The app provides full bilingual support with the following approach:

- Both Arabic and English are fully supported throughout the entire application
- Right-to-left (RTL) layout is handled automatically by Flutter when Arabic is selected
- Arabic font: Cairo or Tajawal; English font: Inter
- Mixed Arabic/English text is handled natively by Flutter's text engine
- Number formatting adapts automatically based on the selected language
- Bottom navigation: Profile | Home | Services | Settings (الملف الرئيسية | الخدمات | الإعدادات)

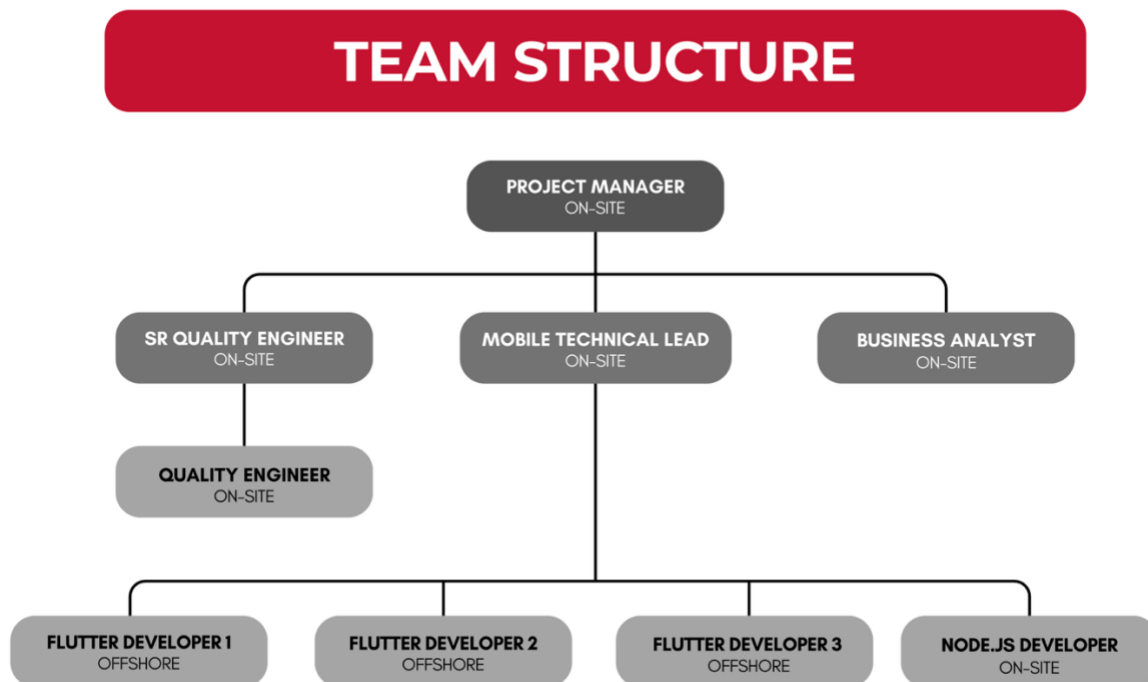
10. Implementation Roadmap

10.1 Delivery Timeline

The project follows a phased approach over approximately 22+ weeks:



10.2 Team Structure



10.3 Phase 0 — Foundation Checklist

Before development begins, the following infrastructure must be in place:

- Set up on-premises servers with Docker runtime
- Configure automated build and deployment pipeline (GitLab CI/CD)
- Set up API Gateway with security certificates
- Initialise the Flutter mobile app project with bilingual support
- Verify all 75 API connections to Oracle EBS
- Set up secure credential storage (HashiCorp Vault)
- Establish monitoring and log collection infrastructure

10.4 Security Testing Checklist

Before go-live, the following security tests must pass:

Test Area	What Is Verified
Authentication Security	No way to bypass login through token manipulation or replay attacks
Certificate Pinning	App rejects connections from intercepting proxies
Device Integrity	Rooted/jailbroken devices are detected and restricted
Input Validation	All data submission endpoints reject malicious payloads
Data Storage	No sensitive data stored in plain text on the device
App Binary	App code is obfuscated; no hardcoded secrets can be extracted

11. Infrastructure & Deployment

11.1 Server Layout

The system runs on HMC's existing server infrastructure:

Server	Role	What It Runs
mwb-01	Web Tier — Primary	API Gateway (NGINX/Kong) in Docker
mwb-02	Web Tier — Secondary	API Gateway (NGINX/Kong) in Docker
mapp-01	Application Tier — Primary	Node.js backend services in Docker
mapp-02	Application Tier — Secondary	Node.js backend services in Docker

11.2 High Availability

The system is designed to remain available even if individual servers experience issues:

- API Gateway runs on two servers (active-active) behind a load balancer with health checks every 5 seconds
- Backend services run on two servers (active-active) with no session dependency — any server can handle any request
- Database connections are pooled and managed automatically for optimal performance
- No single point of failure — the system continues operating if any one component goes down

11.3 Monitoring

System health and performance are continuously tracked:

What Is Monitored	How
API Response Times	Real-time metrics dashboards showing latency and throughput
Error Rates	Automatic logging of all errors with structured details
Request Tracing	Unique tracking ID on every request for end-to-end visibility
Audit Trail	All activity logged and exported to HMC's security monitoring system
Service Health	Automated health checks on every service; load balancer failover
Database Health	Connection pool statistics included in health check responses

12. Risk Register

The following risks have been identified and mitigation strategies are in place:

#	Risk	Likelihood	Impact	Mitigation
R01	Oracle database packages not delivered on time by HMC DBA	Medium	High	API contracts signed off before each module build; validated in Phase 0
R02	Network connectivity issues from App tier to directory services	Low	High	Firewall rules validated in Phase 0; connection testing before development begins
R03	Gateway feature parity with current Layer7 system	Low	Medium	Full mapping of current capabilities reviewed in Phase 0
R04	Certificate pinning issues during certificate rotation	Medium	Medium	Backup pinning approach; documented certificate rotation procedure
R05	Delay in decommissioning old system due to licence exit process	Low	Low	Parallel operation designed from the start; no hard cutover dependency
R06	Changes to clinical system APIs	Medium	Medium	Abstracted behind a versioned adapter that can be updated independently
R07	Phase 3 scope expansion for undecided systems	High	Medium	Architecture supports adding new services without restructuring
R08	Exposure of production database credentials	Low	Critical	Network isolation; all credentials loaded from encrypted vault, never from code
R09	External identity provider decision still pending	High	Medium	Auth service designed to support additional login methods; current flow unaffected

13. Assumptions & Open Items

13.1 Assumptions

#	Assumption
A01	HMC will provide all required Oracle database procedures and views for each phase
A02	HMC DBA will set up the production database schema (via MD-120) before testing and production
A03	HMC will provide branding guidelines and logo assets by end of Phase 0
A04	Server infrastructure (mwb and mapp servers, firewalls, load balancers) is provisioned and accessible remotely
A05	Current Layer7 system remains operational as a backup during the Phase 1 transition (4 weeks)
A06	Network firewall rules allow the App tier to connect to Oracle database and Active Directory
A07	Oracle EBS version is compatible with the chosen database driver
A08	Clinical system (Cerner/Oracle Health) APIs are accessible from the App tier
A09	VPN Access will be provided for offshore resources
A10	UX design and assets are provided by HMC

13.2 Open Items

#	Item	Owner	Target
OI01	Confirm identity provider strategy (Azure AD vs. directory-only); affects login extensions	HMC IT Security	Phase 0 close
OI02	Share current gateway configuration for migration mapping	HMC Integration	Phase 0 Week 1
OI03	Confirm old system decommission timeline and licence exit plan	HMC Procurement	Phase 1 cutover
OI04	Confirm mobile device management platform and app distribution method	HMC IT	Phase 0 close
OI05	Provide HMC branding assets and logo files	HMC Communications	Phase 0 Week 2
OI06	Confirm clinical system API documentation and authentication method	HMC Digital Health	Phase 0 close
OI07	Agree on security testing vendor for Phase 1	HMC InfoSec	Phase 0 close
OI09	Phase 3 system dependencies: Chat Bot platform, Learning system, Attendance system	HMC IT / HR	Phase 2 close